

TELECARE

Plateforme de Télémédecine

POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATION

Référentiel : HDS — Hébergement de Données de Santé

Document	PSSI — Politique de Sécurité des Systèmes d'Information
Organisation	TeleCare SAS
Version	1.0
Date d'émission	31 Mars 2025
Statut	Applicable
Classification	Confidentiel — Usage interne
Créateur	BATINA EMMANUELLA

1. Objet et périmètre

1.1 Objet du document

La présente Politique de Sécurité des Systèmes d'Information (PSSI) définit les orientations stratégiques et les exigences fondamentales en matière de sécurité de l'information applicables à TeleCare SAS.

Elle constitue le document fondateur du dispositif de sécurité de TeleCare. Elle s'impose à l'ensemble des collaborateurs, prestataires, sous-traitants et partenaires ayant accès aux systèmes d'information de la société. Elle vise à assurer la protection des données de santé hébergées et traitées par la plateforme, en réponse aux exigences de la certification HDS (Hébergement de Données de Santé).

1.2 Contexte organisationnel

TeleCare est une startup française de télémédecine créée en 2021, comptant plusieurs collaborateurs. Sa plateforme numérique propose :

- Des consultations médicales par vidéo
- L'échange sécurisé de documents médicaux entre professionnels de santé
- La gestion de comptes patients et de dossiers médicaux numériques
- Des interfaces d'intégration avec les systèmes hospitaliers partenaires

La plateforme est utilisée par des médecins, des établissements de santé partenaires et des patients actifs. L'infrastructure repose sur un cloud public avec plusieurs API exposées et des échanges avec des systèmes tiers hospitaliers.

1.3 Périmètre d'application

La présente PSSI s'applique à l'ensemble du système d'information de TeleCare, incluant :

- La plateforme de télémédecine et ses composants applicatifs
- Les API exposées vers les partenaires et les systèmes hospitaliers
- L'infrastructure cloud hébergeant les données de santé
- Les postes de travail et équipements mobiles des collaborateurs
- Les accès des prestataires et sous-traitants

Elle s'impose à :

- L'ensemble des collaborateurs de TeleCare (CDI, CDD, stagiaires, alternants)
- Les prestataires et sous-traitants ayant accès au SI ou aux données de santé
- Les partenaires techniques bénéficiant d'interconnexions avec la plateforme

2. Enjeux et objectifs de sécurité

2.1 Nature des données traitées

TeleCare traite des données à caractère personnel de santé au sens de l'article 9 du RGPD, qui bénéficient d'une protection renforcée. Ces données comprennent :

- Les données d'identité des patients (nom, prénom, date de naissance, numéro de sécurité sociale)
- Les données médicales : antécédents, ordonnances, résultats d'examens, comptes rendus de consultation
- Les enregistrements vidéo ou audio de consultations médicales
- Les métadonnées d'accès aux dossiers patients
- Les données d'identité et d'activité des professionnels de santé

2.2 Objectifs de sécurité — Critères DICT

La politique de sécurité de TeleCare repose sur quatre critères fondamentaux de la sécurité de l'information, adaptés au contexte médical :

Critère	Désignation	Enjeu pour TeleCare
D	Disponibilité	La plateforme de télémédecine doit être accessible en permanence pour garantir la continuité des soins. Une interruption de service peut entraîner des conséquences directes sur la prise en charge des patients.
I	Intégrité	Les données médicales ne doivent pas être altérées, que ce soit accidentellement ou de façon malveillante. L'exactitude d'un compte rendu ou d'une ordonnance est critique pour la sécurité des patients.
C	Confidentialité	Les données de santé sont soumises au secret médical et au RGPD. Seuls les professionnels habilités et les patients eux-mêmes peuvent accéder aux informations les concernant.
T	Traçabilité	Tout accès aux données de santé doit être enregistré et auditable, conformément aux exigences HDS et RGPD. La traçabilité permet de détecter les accès non autorisés et de répondre aux obligations réglementaires.

3. Gouvernance de la sécurité

3.1 Rôles et responsabilités

La gouvernance de la sécurité de l'information chez TeleCare s'articule autour des rôles suivants :

Acteur	Responsabilités principales	Périmètre d'action
Direction Générale	Validation de la PSSI, arbitrage des investissements sécurité, engagement vis-à-vis de la certification HDS	Ensemble de l'organisation TeleCare
RSSI	Pilotage de la sécurité SI, élaboration et mise à jour des politiques, suivi des incidents, relations avec les auditeurs HDS	Système d'information complet
DPO (Délégué à la Protection des Données)	Conformité RGPD, gestion des demandes d'exercice de droits, notification CNIL en cas de violation de données	Données à caractère personnel, données de santé
Responsables d'équipes DevOps / Ingénierie	Application des exigences sécurité dans les développements, revues de code, sécurisation de l'infrastructure cloud	Plateforme, API, infrastructure
Équipe support et exploitation	Gestion des accès utilisateurs, application des procédures d'exploitation, remontée des incidents	Applications métier, comptes utilisateurs
Tous les collaborateurs	Respect de la présente PSSI et des politiques associées, signalement de tout incident ou anomalie au RSSI	Périmètre de leur activité

3.2 Cadre documentaire

La présente PSSI est le document de référence de la sécurité de TeleCare. Elle est complétée par un ensemble de politiques et procédures spécifiques :

- Politique de protection des données de santé
- Politique de sécurité des API
- Politique de gestion des incidents de sécurité
- Politique de gestion des habilitations
- Charte informatique utilisateur

Ces documents sont maintenus par le RSSI, approuvés par la Direction Générale, et révisés au minimum une fois par an ou à chaque évolution significative du système d'information.

4. Principes fondamentaux de sécurité

4.1 Gestion des accès et des habilitations

L'accès aux ressources du système d'information de TeleCare est régi par les principes suivants :

- Moindre privilège : chaque utilisateur ne dispose que des droits strictement nécessaires à l'exercice de ses fonctions.
- Séparation des rôles : les fonctions critiques (développement, administration, exploitation) sont cloisonnées.
- Authentification forte (MFA) : obligatoire pour tous les accès aux environnements hébergeant des données de santé et pour les administrateurs.
- Revue périodique des droits : les habilitations font l'objet d'une revue trimestrielle par le RSSI et les responsables d'équipes.
- Révocation immédiate : tout départ ou changement de fonction donne lieu à une révocation sans délai des accès correspondants.

4.2 Protection des données de santé

- Chiffrement en transit : toutes les communications sont chiffrées via TLS 1.2 minimum.
- Chiffrement au repos : les données de santé stockées sont chiffrées par des mécanismes conformes aux recommandations de l'ANS.
- Cloisonnement des données : les données de santé sont isolées des autres données et environnements.
- Minimisation des données : seules les données strictement nécessaires aux finalités médicales sont collectées et traitées.
- Durées de conservation : les données sont conservées selon les durées légales applicables au secteur de la santé.

4.3 Sécurité des développements

- Intégration de la sécurité dès la conception (Security by Design)
- Revue de code systématique avant mise en production
- Tests de sécurité (SAST, DAST) intégrés dans la chaîne CI/CD
- Séparation stricte des environnements de développement, de test et de production
- Gestion sécurisée des secrets (clés API, tokens, mots de passe) via un gestionnaire de secrets dédié

4.4 Sécurité des API

- Authentification forte sur toutes les API exposées (OAuth 2.0 / OpenID Connect)
- Contrôle de version et documentation des API exposées à des tiers
- Limitation des appels (rate limiting) pour prévenir les abus
- Journalisation systématique de tous les appels API manipulant des données de santé

- Chiffrement de bout en bout des flux API transportant des données médicales

4.5 Traçabilité et journalisation

- Journalisation de tous les accès aux données de santé (lecture, modification, suppression).
- Journalisation des actions d'administration des systèmes critiques.
- Conservation des logs d'accès aux données de santé : 20 ans minimum selon l'article R.1112-7 du Code de la santé publique.
- Protection des journaux contre toute modification ou suppression non autorisée.
- Supervision active des événements de sécurité avec alertes en cas d'anomalie.

4.6 Gestion des incidents de sécurité

- Tout collaborateur est tenu de signaler immédiatement tout incident de sécurité au RSSI
- Une procédure formalisée de gestion des incidents est en vigueur et applicable à tous
- En cas de violation de données de santé présentant un risque pour les droits et libertés des personnes, la CNIL est notifiée dans un délai maximal de 72 heures
- Lorsque requis par la réglementation applicable ou par les engagements contractuels, l'Agence du Numérique en Santé (ANS) est informée de tout incident impactant des données de santé
- Les patients concernés par une violation sont informés dans les délais légaux

4.7 Continuité de service

- Un Plan de Continuité d'Activité (PCA) est défini, documenté et testé annuellement
- Les sauvegardes des données de santé sont réalisées quotidiennement et vérifiées régulièrement
- Des procédures de reprise d'activité (PRA) sont définies pour les services critiques
- Les objectifs de reprise (RTO et RPO) sont définis en cohérence avec les engagements pris auprès des établissements de santé partenaires

5. Exigences spécifiques HDS

5.1 Obligations légales et réglementaires

TeleCare est soumise aux obligations suivantes en tant qu'hébergeur infogérant de données de santé :

- Article L.1111-8 du Code de la santé publique : obligation de certification HDS pour tout hébergeur de données de santé
- RGPD (Règlement Général sur la Protection des Données) : traitement licite, loyal et transparent des données à caractère personnel
- Code de la santé publique et RGPD : respect du secret professionnel, de la confidentialité et de la sécurité des données de santé
- Référentiel HDS de l'ANS : respect de l'ensemble des exigences de la certification dans le périmètre infogérant

5.2 Contractualisation avec les établissements de santé

Tout établissement de santé ou professionnel de santé confiant des données à TeleCare doit avoir signé un contrat d'hébergement de données de santé conforme aux exigences légales, précisant notamment :

- La nature et le volume des données hébergées
- Les finalités du traitement et les durées de conservation
- Les mesures de sécurité mises en place par TeleCare
- Les conditions d'accès et de restitution des données
- Les obligations de notification en cas d'incident

5.3 Hébergement cloud et sous-traitance

TeleCare fait appel à un cloud provider (infrastructure publique) pour l'hébergement de son infrastructure. Dans ce contexte :

- Le cloud provider retenu doit présenter les certifications appropriées (HDS périmètre infrastructure)
- Un contrat encadrant la sous-traitance des données de santé est en place
- TeleCare conserve la responsabilité de la sécurité au niveau applicatif et de la gestion des accès
- Une cartographie des flux de données entre TeleCare et son cloud provider est maintenue à jour

6. Sensibilisation et formation

La sécurité des données de santé est l'affaire de tous. TeleCare s'engage à :

- Organiser une formation obligatoire à la sécurité des données de santé pour tout nouveau collaborateur, dès son intégration
- Réaliser des sessions annuelles de sensibilisation couvrant les bonnes pratiques, les risques cyber et les obligations HDS/RGPD
- Communiquer régulièrement sur les menaces actuelles (phishing, ingénierie sociale, compromission de comptes)
- Former les développeurs aux pratiques de développement sécurisé (OWASP, sécurité API)
- Former les administrateurs aux exigences de traçabilité et de gestion des accès privilégiés

Les attestations de formation sont conservées et tenues à disposition dans le cadre des audits HDS.

7. Contrôle, audit et amélioration continue

7.1 Revue de la politique

La présente PSSI est soumise à révision annuelle par le RSSI, ou de manière anticipée en cas d'évolution significative :

- Modification substantielle du système d'information
- Évolution réglementaire ou normative (HDS, RGPD, NIS2)
- Incident de sécurité majeur
- Résultat d'audit interne ou externe défavorable

7.2 Audits internes

Des audits internes de sécurité sont réalisés au minimum une fois par an par le RSSI ou par un prestataire mandaté. Ces audits couvrent :

- Le respect des politiques et procédures de sécurité
- La vérification des habilitations et des revues de droits
- Le contrôle des journaux d'accès aux données de santé
- La vérification de la conformité HDS

7.3 Gestion des non-conformités

Toute non-conformité identifiée lors d'un audit ou d'un contrôle fait l'objet :

- D'une analyse des causes
- D'un plan d'action corrective avec délais et responsables identifiés
- D'un suivi de la mise en œuvre des actions correctives
- D'une vérification de l'efficacité des mesures prises

8. Manquements et sanctions

Le non-respect de la présente PSSI ou des politiques associées peut entraîner des mesures disciplinaires pouvant aller jusqu'au licenciement pour faute grave, sans préjudice des poursuites civiles ou pénales encourues.

Les violations graves, notamment tout accès non autorisé à des données de santé, toute divulgation de données confidentielles ou tout contournement des contrôles de sécurité, sont immédiatement portées à la connaissance de la Direction Générale et du DPO. Elles peuvent, le cas échéant, faire l'objet d'une notification aux autorités compétentes, conformément aux obligations légales et réglementaires applicables (notamment CNIL, et ANS lorsque requis).

9. Approbation et entrée en vigueur

Rédigé par	BATINA EMMANUELLA
Vérifié par	DEFFO FRANCK
Date d'approbation	31 Mars 2025
Date d'entrée en vigueur	07 Avril 2025

Engagement de la Direction

La Direction Générale de TeleCare s'engage à soutenir la mise en oeuvre de la présente politique, à allouer les ressources nécessaires à la sécurité des données de santé, et à promouvoir une culture de la sécurité au sein de l'organisation.

Cette politique reflète notre engagement envers nos patients, nos partenaires de santé et nos obligations réglementaires au titre de la certification HDS.

Signature du RSSI Nom : _____ Date : _____	Signature de la Direction Générale Nom : _____ Date : _____
---	--